

ACTIVIDAD 3

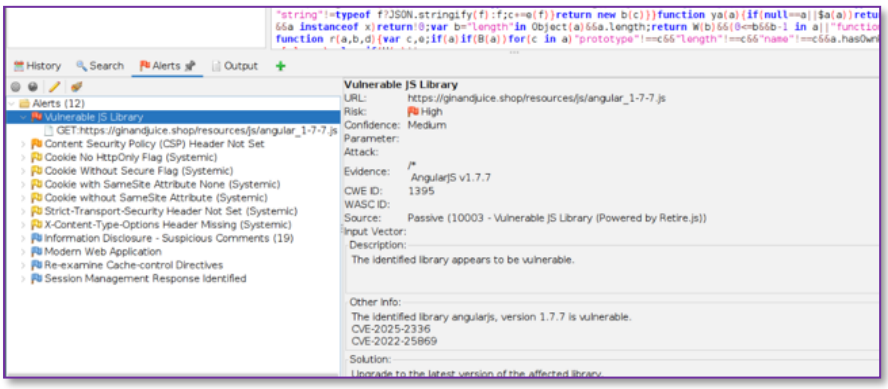
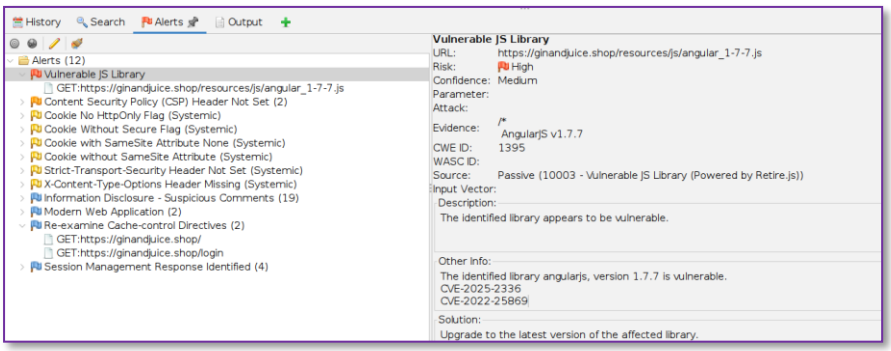
OWASP ZAP

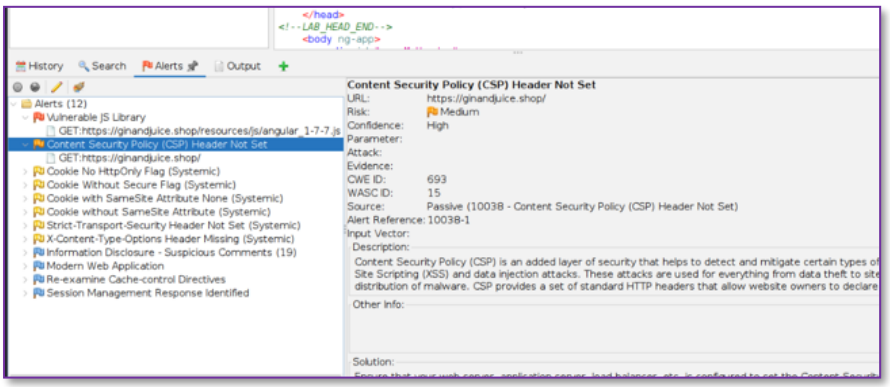
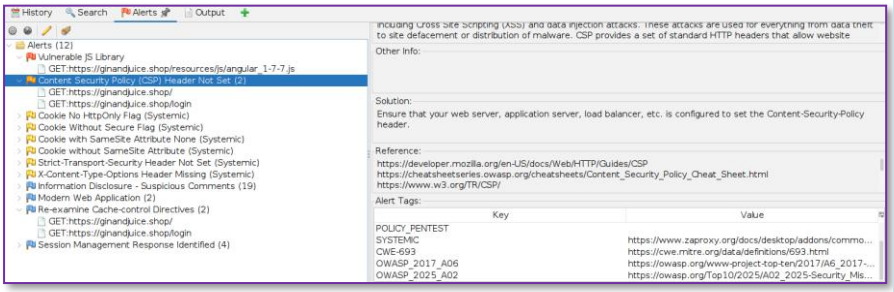
Participante:

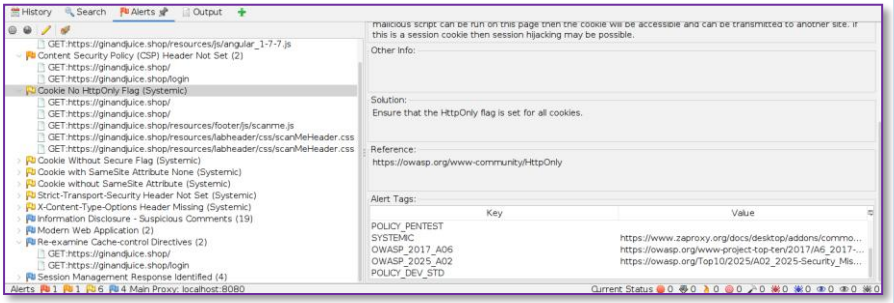
Deyra Salazar Avila

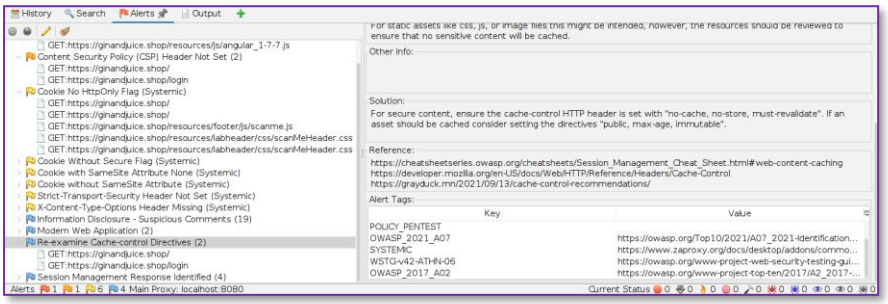
24 de octubre de 2026

DESARROLLO

1	**Nombre de la alerta**	Vulnerable JS Library (AngularJS 1.7.7)
2	**Nivel de riesgo**	Alto (clasificación de ZAP; confianza media)
3	**URL o componente**	https://ginandjuice.shop/resources/js/angular_1-7-7.js
4	**Parámetro afectado**	Biblioteca AngularJS v1.7.7; componente JavaScript del cliente.
5	**Evidencia**	ZAP identifica AngularJS v1.7.7 y cita CVE-2025-2336 y CVE-2022-25869.  
6	**Descripción técnica**	La aplicación utiliza una versión antigua de AngularJS asociada a vulnerabilidades conocidas. La detección de la biblioteca no confirma por sí misma una explotación.
7	**Impacto potencial**	Según el código y el uso de la biblioteca, podría facilitar ataques contra el comportamiento del cliente; la explotabilidad concreta requiere validación.
8	**Recomendación**	Migrar a un framework o versión mantenida, actualizar dependencias, verificar CVE aplicables y ejecutar pruebas de regresión.

1	**Nombre de la alerta**	Content Security Policy (CSP) Header Not Set
2	**Nivel de riesgo**	Medio (clasificación de ZAP; confianza alta)
3	**URL o componente**	https://ginandjuice.shop/
4	**Parámetro afectado**	Cabecera HTTP Content-Security-Policy (ausente).
5	**Evidencia**	La alerta pasiva 10038 señala la ausencia de CSP en la respuesta a GET /.  
6	**Descripción técnica**	La aplicación web no implementa el encabezado HTTP Content-Security-Policy (CSP), que permite restringir las fuentes de contenido autorizadas. Su ausencia reduce la protección del navegador frente a ataques como Cross-Site Scripting (XSS), inyección de código y carga de recursos maliciosos. El servidor no comunica al navegador una política CSP que limite los orígenes permitidos para scripts y otros recursos.
7	**Impacto potencial**	La ausencia del encabezado CSP incrementa el riesgo de ejecución de scripts maliciosos y carga de recursos externos no autorizados. Si un atacante logra explotar una vulnerabilidad XSS, la falta de esta protección podría facilitar el robo de información sensible, la manipulación del contenido web, el secuestro de sesiones o la redirección de usuarios hacia sitios fraudulentos.
8	**Recomendación**	Implementar una CSP restrictiva adaptada a la aplicación; probar primero con Report-Only y monitorear violaciones antes de aplicarla.

1	**Nombre de la alerta**	Cookie No HttpOnly Flag (Systemic)
2	**Nivel de riesgo**	Bajo (clasificación de ZAP- Confianza Media)
3	**URL o componente**	https://ginandjuice.shop/ y otros recursos del sitio.
4	**Parámetro afectado**	Cabecera Set-Cookie; atributo HttpOnly de la cookie AWSALB.
5	**Evidencia**	En la respuesta se observa AWSALB sin HttpOnly, mientras que la cookie session sí muestra HttpOnly. ZAP lista la alerta sistémica.  
6	**Descripción técnica**	La aplicación establece cookies sin el atributo HttpOnly, permitiendo su acceso mediante JavaScript. Esto representa un riesgo de exposición de cookies ante ataques XSS y podría facilitar el secuestro de sesiones si las cookies contienen identificadores de autenticación.
7	**Impacto potencial**	La ausencia del atributo HttpOnly permite que las cookies sean accesibles mediante JavaScript. Si un atacante logra ejecutar código malicioso mediante una vulnerabilidad XSS, podría obtener cookies que contengan identificadores de sesión o información sensible. Esto podría ocasionar robo de información, secuestro de sesiones y acceso no autorizado a funcionalidades de la aplicación mediante la suplantación de usuarios legítimos.
8	**Recomendación**	Habilitar HttpOnly en cookies que no deban leerse desde JavaScript, priorizando las de sesión; revisar Secure y SameSite y validar el balanceador.

1	**Nombre de la alerta**	Re-examine Cache-control Directives
2	**Nivel de riesgo**	Informativo (clasificación de ZAP; confianza baja)
3	**URL o componente**	https://ginandjuice.shop/
4	**Parámetro afectado**	Cabecera HTTP Cache-Control; almacenamiento en caché.
5	**Evidencia**	ZAP genera la alerta pasiva 10015 para revisar las directivas de caché en GET /.  
6	**Descripción técnica**	La aplicación presenta una configuración ausente o inadecuada del encabezado HTTP Cache-Control, lo que podría permitir el almacenamiento de respuestas web en la caché del navegador o de servidores intermediarios. Si estas respuestas contienen información sensible, podrían quedar almacenadas sin las restricciones de seguridad correspondientes.
7	**Impacto potencial**	Una configuración incorrecta del encabezado Cache-Control podría permitir que páginas web con información confidencial, datos personales o contenido de sesiones autenticadas sean almacenadas en la caché del navegador o de servidores proxy compartidos. Esto incrementaría el riesgo de exposición de información sensible y acceso no autorizado, especialmente en equipos compartidos o cuando otros usuarios puedan acceder al contenido almacenado.
8	**Recomendación**	Para respuestas con información privada usar Cache-Control: no-store según el caso; permitir caché controlada en recursos públicos y validar cabeceras.

RESUMEN DE ALERTAS IDENTIFICADAS

Nivel de riesgo	Nombre de la alerta	URL / componente	Parámetro / elemento	Evidencia registrada
Alto	Vulnerable JS Library (AngularJS 1.7.7)	/resources/js/ angular_1-7-7.js	Biblioteca AngularJS v1.7.7	ZAP identifica AngularJS v1.7.7 y cita CVE-2025-2336 y CVE-2022-25869.
Medio	Content Security Policy (CSP) Header Not Set	1. https://ginandjuice.shop/ 2. https://ginandjuice.shop/catalog 3. https://ginandjuice.shop/catalog/product (productId) 4. https://ginandjuice.shop/login	Encabezado HTTP Content-Security-Policy (ausente)	Alerta pasiva 10038: la respuesta HTTP a GET / no incorpora CSP.
Bajo	Cookie No HttpOnly Flag (Systemic)	1. https://ginandjuice.shop/ 2. https://ginandjuice.shop/ 3.https://ginandjuice.shop/resources/footer/js/scanme.js 4.https://ginandjuice.shop/resources/labheader/css/scanMeHeader.css 5.https://ginandjuice.shop/resources/labheader/css/scanMeHeader.css	Cookie AWSALB; atributo HttpOnly	Set-Cookie de AWSALB sin HttpOnly; la cookie session observada sí lo presenta.
Informativo	Re-examine Cache-control Directives	1.https://ginandjuice.shop/ 2.https://ginandjuice.shop/catalog 3.https://ginandjuice.shop/catalog/product 4.https://ginandjuice.shop/login	Encabezado HTTP Cache-Control	Alerta pasiva 10015: se recomienda revisar las directivas de caché en GET /.

CONCLUSIONES

El desarrollo de esta actividad permitió comprender la importancia de OWASP ZAP como herramienta para la evaluación de la seguridad de aplicaciones web, mediante el análisis del tráfico HTTP/HTTPS y la identificación de posibles vulnerabilidades y configuraciones inseguras. A través de la evaluación de Gin & Juice Shop, aprendí a interpretar las alertas generadas, reconocer sus niveles de riesgo, identificar las URL y los componentes afectados, y recopilar evidencias técnicas que sustenten los hallazgos. Asimismo, comprendí que la detección de una vulnerabilidad potencial no implica necesariamente que haya sido explotada, por lo que es fundamental validar los resultados antes de determinar su impacto real.

Uno de los principales desafíos fue comprender la estructura de las solicitudes y respuestas HTTP, identificar los parámetros y encabezados involucrados y relacionarlos con las alertas detectadas. Para superar estas dificultades, exploré las funcionalidades de OWASP ZAP, especialmente las pestañas Request, Response y Alerts, lo que me permitió analizar detalladamente cada hallazgo y documentarlo de manera ordenada. Esta experiencia reforzó mis conocimientos sobre la importancia de interpretar correctamente las evidencias, evitar falsos positivos y diferenciar entre debilidades de configuración, componentes vulnerables y ataques efectivamente comprobados.

Finalmente, considero necesario complementar esta evaluación con pruebas adicionales sobre los mecanismos de autenticación, gestión de sesiones, búsqueda de productos y protección de información sensible. También profundizaría en la revisión de bibliotecas desactualizadas, políticas de seguridad de contenido (CSP), atributos de seguridad de las cookies y directivas de almacenamiento en caché. Como siguiente etapa, realizaría pruebas activas controladas de SQL Injection y Cross-Site Scripting (XSS), dentro de un entorno autorizado, para verificar la existencia y explotabilidad de otras vulnerabilidades. En conclusión, esta práctica me permitió fortalecer mis habilidades iniciales en análisis de seguridad web y comprender que una evaluación efectiva requiere combinar herramientas automatizadas, análisis manual, interpretación técnica y recomendaciones orientadas a reducir los riesgos de seguridad.